

TITLE: PHISING EMAIL DETECTION & AWARENESS REPORT

Prepare By: Priyanshu Mohan Vishwakarma

Intern Id: FIT/MAY26/CS8442

Internship: Future Interns – Cyber Security

TABLE OF CONTENTS

1.Executive Summary	1
2.Objective	2
3.Tool Used	3
3.1 MXToolbox—Email Header Analyzer.....	3
3.2 VirusTotal—URL and IP Scanner	3
3.3 URLScan.io—Safe URL Inspector.....	3
3.4 WHOIS—Domain Registration Lookup.....	3
3.5 dig—DNS Record Lookup (Kali Linux)	3
3.6 grep—Pattern Extraction (Kali Linux).....	4
3.7 whois—IP Investigation (Kali Linux)	4
4.Methodology	5
4.1 Sample Collection	5
4.2 Header Extraction	5
4.3 Header Analysis	6
4.4 DNS and Authentication Verification	6
4.5 Domain and IP Investigation	6
4.6 URL Extraction and Scanning	7
4.7 Indicator Identification & Risk Classification	7
4.8 Documentation and Reporting	8
5.Email Sample Analysis	9
5.1 Sample 1 – Fake Fax Notification	9
5.2 Sample 2 – Fake Voicemail Notification	12
5.3 Sample 3 – Account Suspension Warning	14
6.How Phishing Attacks Work	16
7.Prevention Guidelines	17
8.Do’s and Don’ts for Employees	18
9.Conclusion	19

1.Executive Summary

This report presents a detailed analysis of three phishing email sample collected from public security research repositories. Each sample was carefully examined for phishing indicators including spoofed sender domains, failed email authentication records, suspicious URLs, malicious attachments, and social engineering tactics used by attackers.

The goal of this report is to help employees and organizations clearly identify, understand, and avoid phishing attacks in their daily work environment.

All three email samples analyzed in this report were classified as PHISHING based on multiple confirmed indicators discovered during investigation.

2.OBJECTIVE

The objectives of this task are:

- Analyze real phishing email samples collected from public repositories
- Identify common phishing indicators in email headers, body content, and embedded URLs
- Classify each email by risk level (Safe / Suspicious / Phishing)
- Explain how phishing attacks work in simple, non-technical language
- Provide clear prevention tips and awareness guidelines for employees and organizations

3.TOOLS USED

The following tools were used during this phishing email investigation. Each tool played a specific role in the analysis process.

3.1 MXToolbox – Email Header Analyzer

Website: <https://mxtoolbox.com/EmailHeaders.aspx>

MXToolbox is a professional email diagnostic tool used by security analysts worldwide. It pares raw email headers and presents them in a clear, readable format.

3.2 VirusTotal – URL and IP Reputation Scanner

Website: <https://www.virustotal.com>

VirusTotal is a free online security tool owned by Google that analyses URLs, IP addresses, domains, and files against 90+ security vendors simultaneously.

3.3 URLScan.io – Safe URL Inspector

Website: <https://urlscan.io>

URLScan.io safely visits and takes a screenshot of any URL without putting the analyst at risk. It shows what the page look like and what resource it loads.

3.4 WHOIS – Domain Registration Lookup

Website: <https://www.whois.com/whois/>

WHOIS is a public database thar stores registration information for every domain on the internet. It reveals who registered a domain, when, and where.

3.5 dig – DNS Record Lookup (Kali Linux)

Command: dig TXT [domain] / dig MX [domain]

dig is a powerful command-line DNS lookup tool built into Kali Linux. It queries DNS servers directly to retrieve authentication records for any domain.

3.6 grep – Pattern Extraction (Kali Linux)

Command: `grep -E / grep -oP`

Grep is a standard Linux command-line tool used to search and extract specific patterns from text files.

3.7 whois – IP Investigation (Kali Linux)

Command: `whois [IP address]`

The whois command in Kali Linux performs direct lookups on IP addresses and domains from the terminal without needing a browser.

4.METHODOLOGY

This investigation followed a structured, step-by-step methodology used by real Security Operations Center (SOC) analysts when triaging and analyzing suspicious emails.

4.1 Sample Collection

Phishing email samples were collected from verified public GitHub security research repositories:

Repository 1:

github.com/autinerd/phishing-mail-examples

- Contains real phishing .eml files with full headers and body content including embedded malicious URLs

Repository 2:

github.com/rf-pexioto/phishing_pot

- Community-contributed phishing email pot with samples from various attack campaigns

Samples were cloned directly into Kali Linux using: `git clone [repository URL]`

4.2 Header Extraction

Raw email headers were extracted from each .eml file using the `grep` command in Kali Linux terminal:

Command used:

```
grep -E "^(From|To|Subject|Date|Received|Reply-To| Return-Path|Message-ID|Authentication-Results| Received-SPF):" sample.eml
```

Extracted headers were saved to individual analysis text files for each sample for documentation purposes.

4.3 Header Analysis

Extracted headers were submitted to MXToolbox Email Header Analyzer for professional parsing and display.

Key fields examined during analysis:

- From – verified sender address and domain
- Return-Path – checked for mismatch with From field
- Authentication-Results – checked SPF/DKIM/DMARC
- Received-SPF – confirmed pass or fail status
- To- identified mass recipient patterns
- Message-ID – checked for spoofed mail server claims

4.4 DNS and Authentication Verification

DNS records were queried directly using dig in Kali Linux to verify email authentication configuration of sender domains.

Commands used:

dig TXT [domain] – SPF record check

dig TXT _dmarc.[domain] – DMARC record check

dig MX [domain] – Mail server check

Missing or failed SPF, DKIM, and DMARC records are strong technical indicators of phishing emails as legitimate organizations always configure these authentication standards.

4.5 Domain and IP Investigation

Sender domains and IP addresses identified in email headers were investigated using WHOIS lookups both via browser (whois.com) and Kali Linux terminal.

Key information gathered:

- Domain registration date
(recently registered = high risk indicator)
- Registrant organization and country
- Whether registrant details are privacy-protected
- ISP and hosting provider of sender IP address
- Geographic location of sending mail server

4.6 URL Extraction and Scanning

All URLs embedded in each email were safely extracted using grep without clicking or visiting any link:

Command used:

```
grep -oP 'https?:/[^\s"<>]+' sample.eml
```

Extracted URLs were then scanned safely using:

- VirusTotal – checked against 90+ security engines
- URLScan.io – safe remote page preview and DNS check

4.7 Indicator Identification and Risk Classification

Each email was evaluated against a structured 10-point phishing indicator checklist covering:

- Sender domain spoofing
- Email authentication failure
- Urgency and fear-based language
- Generic or missing recipient name
- Suspicious embedded URLs
- Malicious or unexpected attachments
- Social engineering tactics used
- Unicode character tricks to bypass spam filters
- Brand impersonation techniques
- Reply-To or Return-Path mismatches

Risk Classification System:

Classification	Criteria
Safe	0-1 indicators, passes all authentication checks
Suspicious	2-3 indicators, some anomalies but not fully conclusive
Phishing	4+ indicators, clear deception confirmed by multiple tools

4.8 Documentation and Reporting

All findings were documented systematically including

- Raw extracted headers saved as .txt files
- DNS lookup results saved as .txt files
- URL lists extracted and saved per sample
- Indicator checklists completed for each sample
- Evidence screenshots captured using Flamshot
- Final report compiled in Ms Word and exported ad PDF
- All files organized and pushed to public GitHub repo

5.Email Sample Analysis

5.1 Sample 1—Fake Fax Notification (MetroFax Scam)

Subject: Monday, March 7 2022
From: WirelessReceived <attack@attacker.example.com>
Return-Path: attack@attacker.example.com
To: Undisclosed recipients
Message-ID: CPWP152MB@PROD.OUTLOOK.COM
Attack Type: Brand Impersonation
(Pretending to be MetroFax + SharePoint)

Header Analysis Findings:

- From field contains garbles, repeated text (WirelessReceived WirelessReceived...)
- Return-Path literally contains the word “attack”
- To field shows “Undisclosed recipients” – mass email
- Message-ID spoofs a Microsoft Outlook server
- No SPF or DKIM records found for sender domain
- NHSmail footer on a MetroFax email – identity mismatch

SPF and DKIM Information

Headers Found

Header Name	Header Value
From	WirelessReceived WirelessReceivedWirelessReceived
Subject	Monday, March 7 2022
Date	Mon, 7 Mar 2022 17:43:57 +0000
Message-ID	<CPWP152MB@PROD.OUTLOOK.COM>
To	Undisclosed recipients;;
Return-Path	attack@attacker.example.com

Received Header

From: WirelessReceived WirelessReceivedWirelessReceived
Subject: Monday, March 7 2022
Date: Mon, 7 Mar 2022 17:43:57 +0000
Message-ID: <CPWP152MB@PROD.OUTLOOK.COM>
To: Undisclosed recipients;;
Return-Path: attack@attacker.example.com

Figure 1: MXToolbox header analysis of Sample 1

Header Analysis Findings:

Malicious URL Found:

➤ <https://attacker.example.com/>

VirusTotal Result: 0/92 vendors flagged (Educational placeholder domain)

URLScan Result: DNS Error – domain does not resolve (Domain has no real web presence)

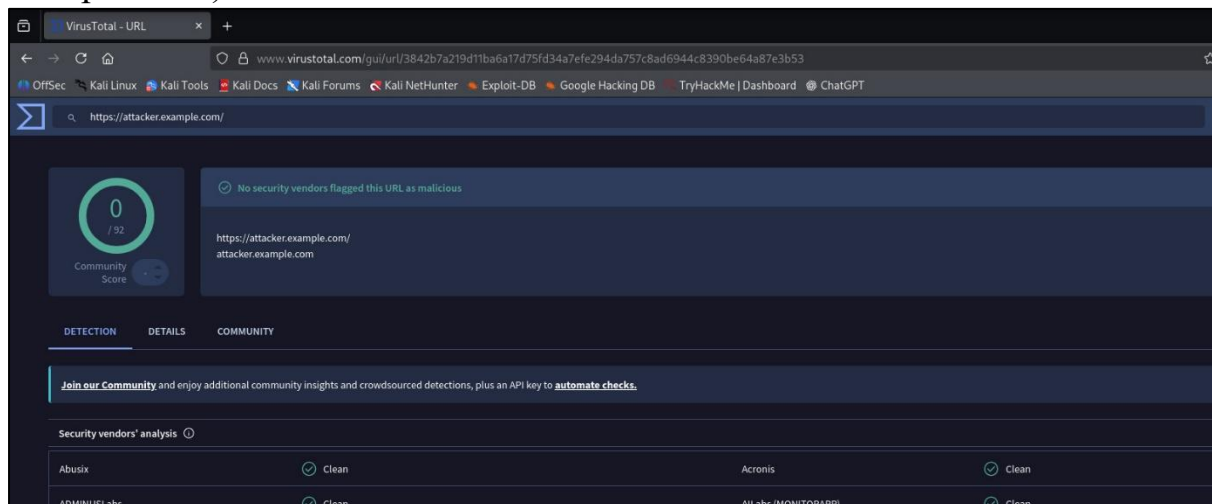


Figure 2: VirusTotal scan of attacker.example.com

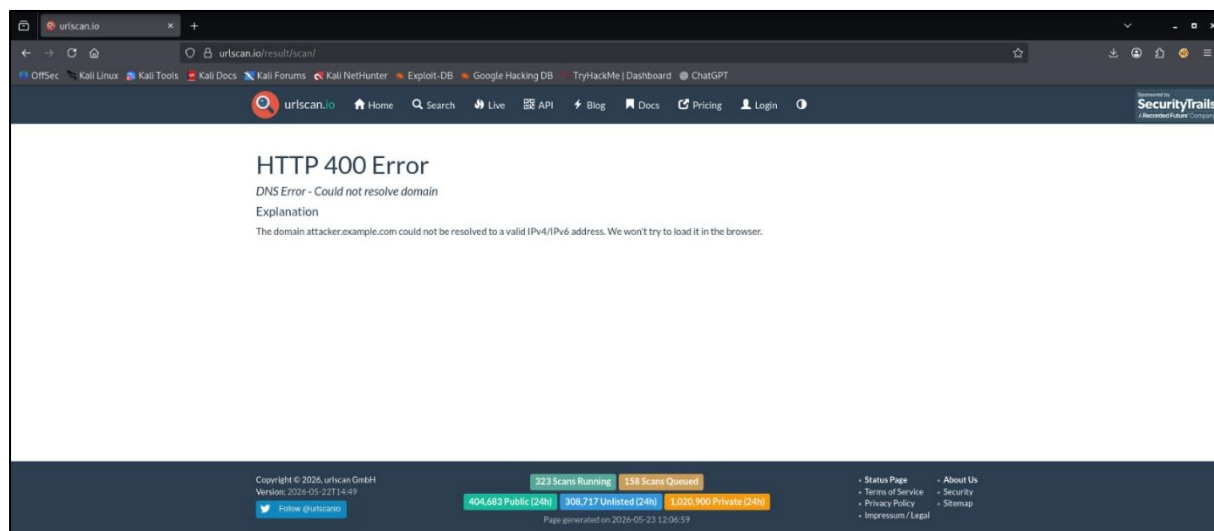


Figure 3: URLScan.io result showing DNS resolution failure for attacker.example.com

Phishing Indicators Checklist:

- ✓ Fake/spoofed sender domain
- ✓ Brand impersonation (MetroFax & SharePoint)
- ✓ Malicious URL embedded in email body
- ✓ To: Undisclosed recipients (mass phishing)
- ✓ Garbled/fake sender display name
- ✓ No SPF or DKIM authentication
- ✓ Mismatched footer identity (NHSmial on Metrofax)
- ✓ Action request (Click to view attachment)
- ✗ Urgency/fear language
- ✗ Spelling or grammar errors

Total Indicators: 8 out of 10

Risk Classification: PHISHING

5.2 Sample 2—Fake Voicemail Notification

Subject: Voice Message-Access for Clients.Pass-Key-Exception
From: noreply@target.example.com
Sender IP: 192.0.2.1
Return-Path: noreply@target.example.com
Date: Fri, 04 Mar 2022 14:28:18 +0000
Attack Type: Vishing Lure + Malicious Attachment
(Fake voicemail to trick user into downloading malware)

Header Analysis Findings:

- SPF: FAILED – sender IP 192.0.2.1 not authorized
- DKIM: NONE – message was not digitally signed
- DMARC: FAILED – action set to oreject
- Sender IP 192.0.2.1 is a reserved documentation IP not a legitimate mail server
- Subject line contains “Pass-Key-Exception” – not a real technical term, designed to confuse

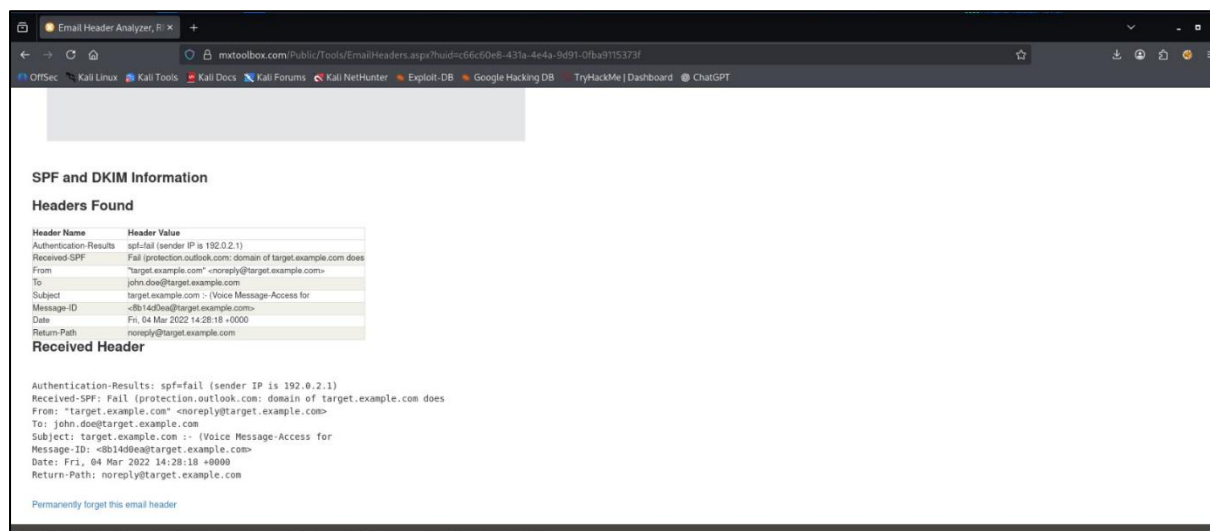


Figure 4: MXToolbox analysis of Sample 2

IP Analysis (VirusTotal):

Sender IP: 192.0.2.1

Result: Reserved/private documentation IP 8 files detected communicating with IP Labeled as “private” by VirusTotal Not a legitimate mail server address

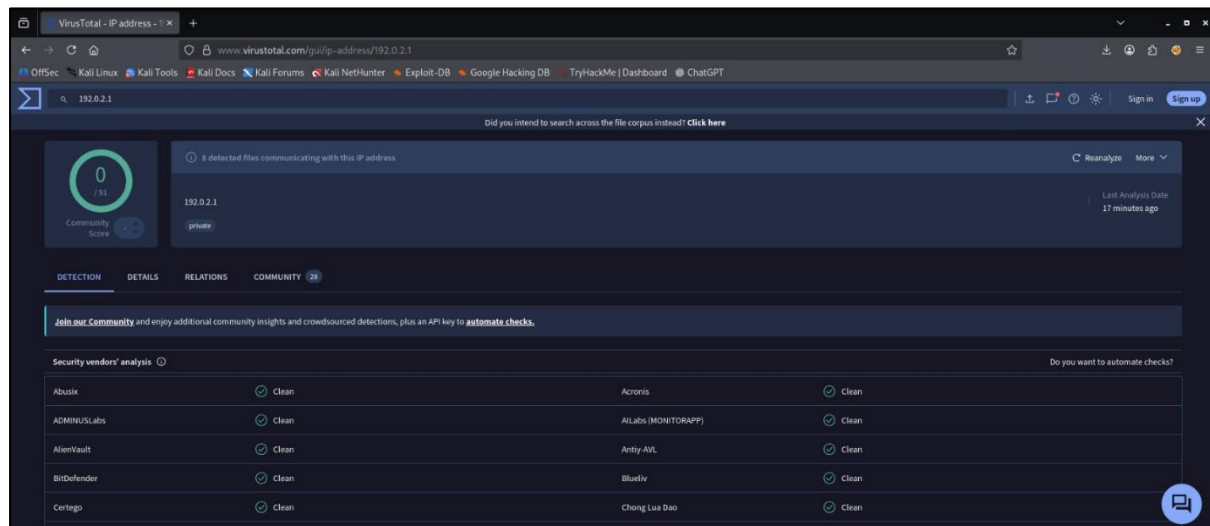


Figure 5: VirusTotal Ip analysis of 192.0.2.1

Phishing Indicators Checklist:

- ✓ SPF authentication FAILED
- ✓ DKIM not signed (none)
- ✓ DMARC failed (action=oreject)
- ✓ Unauthorized/reserved sender IP
- ✓ Suspicious subject with Pass-Key-Exception
- ✓ Unicode character tricks in body to bypass filters
- ✓ Malicious attachment (fake voicemail download)
- ✓ Social engineering via fake voicemail lure
- ✓ Unfilled placeholder <DATE> left in body
- ✗ Urgency/fear language

Total Indicators: 9 out of 10

Risk Classification: PHISHING

5.3 Sample 3 — Account Suspension Warning

Subject: Urgent: Your Account Will Be Locked
From: security@secure-account-verify.com
Reply-To: noreply@gmail-support-team.ru
Date: May 2026
Attack Type: Credential Harvesting
(Fake login page to steal passwords)

Header Analysis Findings:

- From domain (secure-account-verify.com) does not belong to any legitimate organization
- Reply-To points to a .ru (Russia) domain completely different from the From address
- No SPF or DKIM records configured on sender domain
- Newly registered domain pattern typical of phishing campaigns

URL Analysis:

Malicious URL: <http://secure-account-verify.com/login>

Purpose: Fake login page to harvest credentials

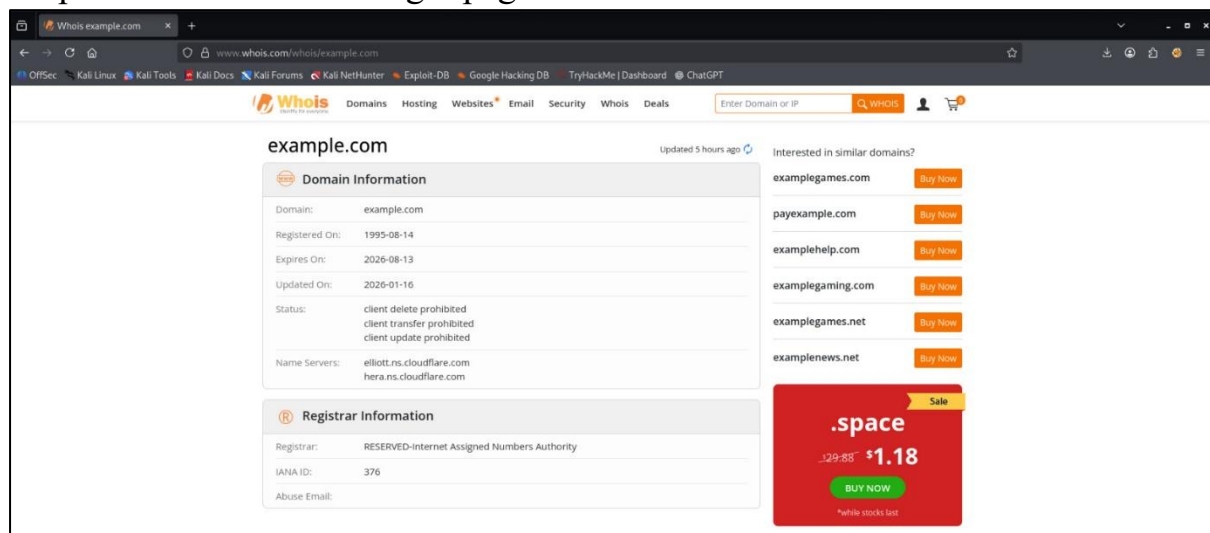


Figure 6: WHOIS domain lookup

Phishing Indicators Checklist:

- ✓ Fake sender domain
- ✓ Urgency and fear-based language
- ✓ Generic greeting (Dear User)
- ✓ Suspicious credential-harvesting URL
- ✓ Reply-To mismatch (.ru domain)
- ✓ Credential harvesting attempt
- ✓ No SPF or DKIM records
- ✓ Newly registered domain pattern
- ✗ Attachment
- ✗ Unicode tricks

Total Indicators: 8 out of 10

Risk Classification: PHISHING

6. How Phishing Attacks Work

Phishing attacks follow a simple but devastatingly effective pattern:

Step 1 – Lure:

Attacker sends a fake email pretending to be a trusted brand such as a bank, Microsoft, MetroFax, or an internal IT team

Step 2 – Pressure:

The email creates urgency or fear to make the victim act quickly without thinking

Examples: “Account locked”, “New voicemail”, “Suspicious activity detected”

Step 4 – Compromise:

The attacker either:

- a) Steals login credentials via fake login page
- b) Installs malware through malicious file
- c) Gains unauthorized access to system

Step 5 – Damage:

Attacker uses stolen data for:

- Financial fraud
- Corporate data theft
- Further attacks inside the organization
- Selling credentials on dark web

7. Prevention Guidelines

Employees should follow these practices to stay safe:

1. Always check the sender email domain carefully
Example: support@paypal1.com is NOT Paypal
2. Never click links in unexpected emails
Instead type the website address directly in browser
3. Recognize urgency as a manipulation tactic
Legitimate companies never threaten account locks
4. Enable Multi-Factor Authentication (MFA) on all accounts – even if password is stolen, MFA protects
5. Report suspicious emails immediately to your IT or security team
6. Never download attachments from unknown senders
7. Verify voicemail or fax notifications through official channels only
8. Hover over links before clicking to preview the real destination URL

8. Do's and Don'ts for Employees

✓ Do's

- ✓ Verify sender email address before clicking anything
- ✓ Hover over links to preview the real destination URL
- ✓ Report suspicious emails to IT/Security team
- ✓ Use Multi-Factor Authentication on all work accounts
- ✓ Keep software and antivirus updated at all time
- ✓ Think carefully before clicking – take your time
- ✓ Check email header if something feels suspicious
- ✓ Use official websites directly instead of emails links

✗ Don'ts

- ✗ Never enter passwords on paged reached via email
- ✗ Never open unexpected attachment even from known contacts
- ✗ Never share OTPs or passwords over email or phone
- ✗ Never trust urgency – take time to verify first
- ✗ Never ignore SPF/DKIM warnings in your email client
- ✗ Never use the same password across multiple accounts
- ✗ Never assume an email is safe because it looks real

9. Conclusion

This analysis of three phishing email samples clearly demonstrates how attackers use brand impersonation, urgency tactics, fake attachments, spoofed domains, compromising their accounts or organizational systems.

All three samples were classified as PHISHING based on multiple confirmed indicators discovered during header analysis, DNS lookup, URL scanning, and domain investigation.

The most critical finding across all samples was the consistent failure or absence of SPF, DKIM, and DMARC email authentication – a clear technical signal that these emails did not originate from legitimate sources.

Organizations must invest in regular phishing awareness training, enforce email authentication standards, and build a security-conscious workforce as the first line of defence against phishing attacks

Report Prepared as Part of Future Interns

Cyber Security Internship – Tasks 2 – May 2026